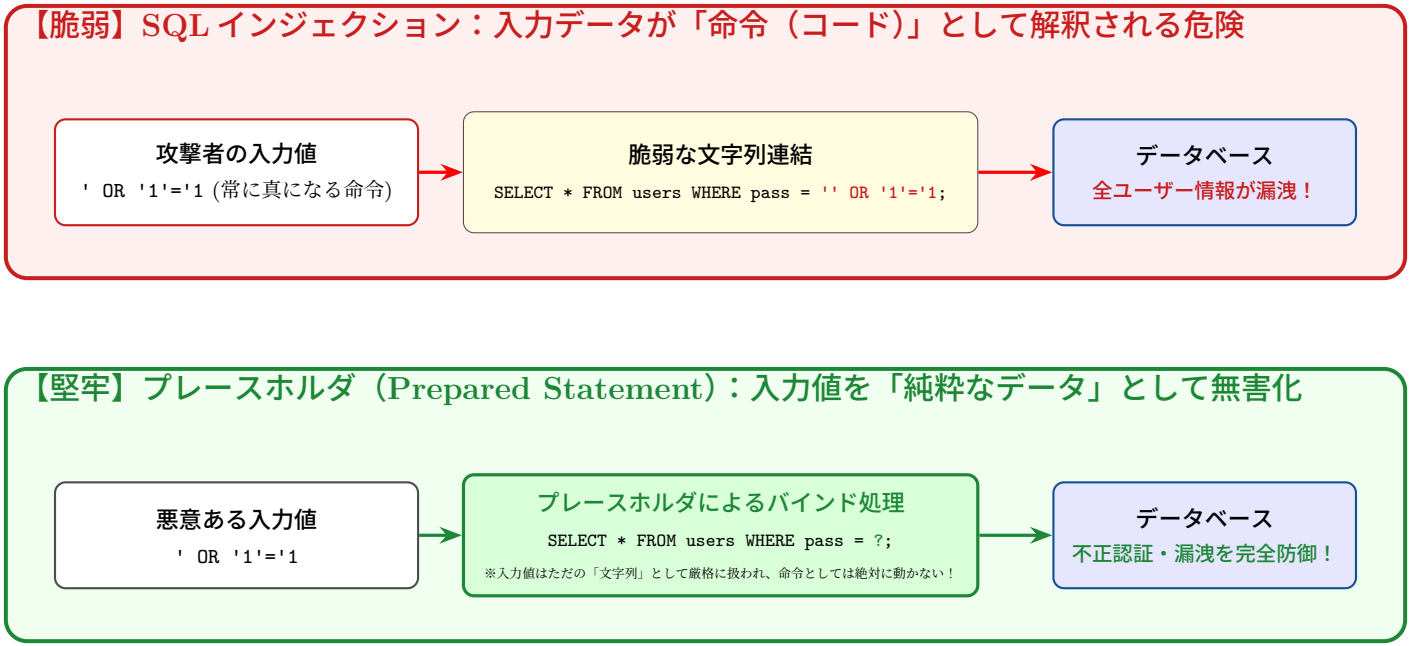
【脆弱】SQL インジェクション：入力データが「命令（コード）」として解釈される危険
攻撃者の入力値
' OR '1'='1 (常に真になる命令)
脆弱な文字列連結
SELECT * FROM users WHERE pass = '' OR '1'='1;
データベース
全ユーザー情報が漏洩！
【堅牢】プレースホルダ（Prepared Statement）：入力値を「純粋なデータ」として無害化
悪意ある入力値
' OR '1'='1
プレースホルダによるバインド処理
SELECT * FROM users WHERE pass = ?;
※入力値はただの「文字列」として厳格に扱われ、命令としては絶対に動かない！
データベース
不正認証・漏洩を完全防御！